SEGURIDAD DE LA INFORMACIÓN

Descubre el arsenal invisible del pentesting en aplicaciones

¿Quieres fortalecer tus defensas digitales? Desliza para conocer las mejores prácticas y herramientas que todo profesional de ciberseguridad debería dominar.

SEGURIDAD DE LA INFORMACIÓN

¿Qué es exactamente el pentesting?

Con el aumento de la superficie de ataque y datos sensibles disponibles 24/7, el pentesting se ha vuelto imprescindible para aplicaciones web y móviles.

Evaluación controlada

Simulación ética de ataques para identificar vulnerabilidades antes que los ciberdelincuentes.

Objetivo preventivo

Identificar fallos de seguridad para evitar brechas de datos y pérdidas económicas.

SEGURIDAD DE LA INFORMACIÓN

Marcos de referencia esenciales

SEGURIDAD INFORMÁTICA CARLA MORENO
CM
SEGURIDAD DE LA INFORMACIÓN

Web: OWASP Top 10

Las vulnerabilidades web más críticas que todo pentester debe conocer y comprobar metódicamente.

Mobile: OWASP MASVS + MASTG

Estándares de verificación y guías técnicas especializadas para aplicaciones móviles.

Buenas prácticas fundamentales

Alcance y permisos

Define claramente qué probar y obtén autorización formal para evitar problemas legales.

Entornos seguros

Utiliza siempre entornos de staging o sandbox, nunca producción directamente.

Metodologías estándar

Sigue OWASP, PTES u OSSTMM para asegurar un proceso completo y estructurado.

Arsenal de herramientas imprescindibles

Web

- *Burp Suite: proxy de interceptación y suite completa*
- *OWASP ZAP: alternativa gratuita a Burp*
- *Nmap: escaneo de puertos y servicios*
- *Nikto: escáner de vulnerabilidades web*

Mobile

- *MobSF: análisis estático y dinámico*
- *Drozer: evaluación de superficies de ataque*
- *Frida: inyección de código y hooking*
- *Objection: toolkit para aplicaciones móviles*

SEGURIDAD INFORMÁTICA CARLA MORENO CIBERSEGURIDAD
CM

Integración con DevSecOps

Automatización

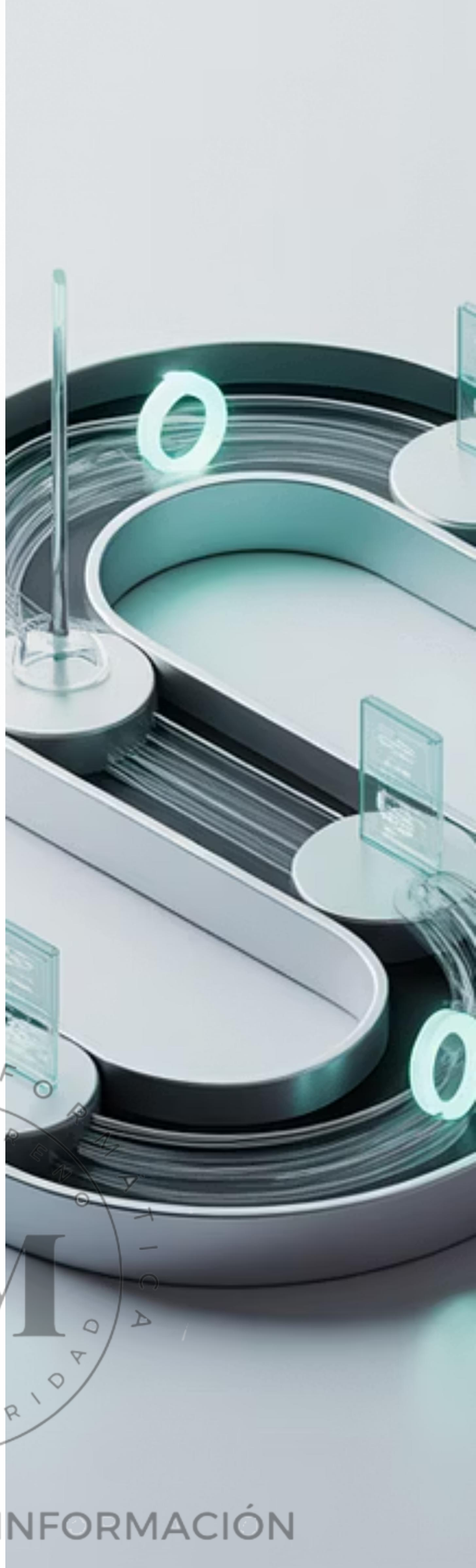
Integra herramientas como OWASP ZAP o MobSF en tus pipelines de CI/CD.

Testing Continuo

Ejecuta análisis de seguridad en cada commit o pull request para detectar vulnerabilidades temprano.

Feedback inmediato

Configura alertas que notifiquen al equipo cuando se detecten fallos de seguridad críticos.



SEGURIDAD INFORMATICA
CARLA MORENO
CM
CIBERSEGURIDAD

Documentación que marca la diferencia

SEGURIDAD INFORMÁTICA
CARLA MORENO
CM
CIBERSEGURIDAD
SEGURIDAD DE LA INFORMACIÓN

Reportes estructurados

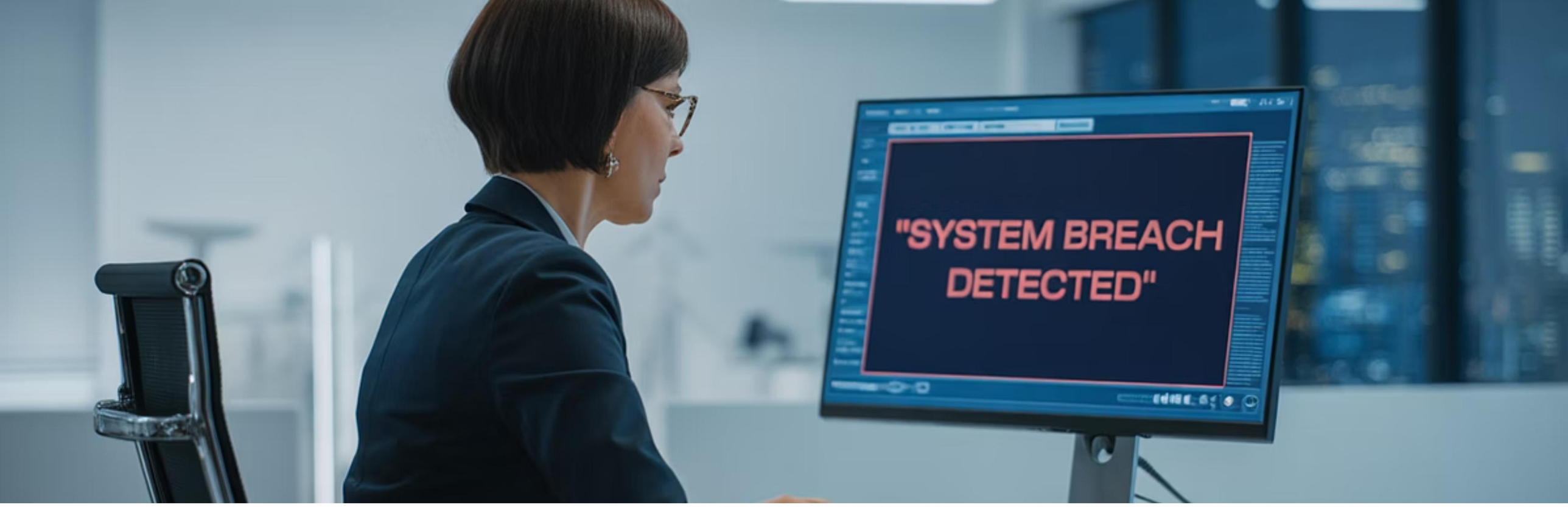
Clasifica vulnerabilidades por severidad (CVSS) y prioriza las más críticas.

Evidencias claras

Documenta cada paso para reproducir el problema con capturas de pantalla.

Recomendaciones accionables

Proporciona soluciones concretas y referencias a buenas prácticas.



Errores críticos que debes evitar

Objetivos ambiguos

No definir correctamente el alcance lleva a pruebas incompletas o excesivas.

Entornos irreales

Probar en sistemas que no reflejan producción genera falsos positivos/negativos.

SEGURIDAD DE LA INFORMACIÓN

Exceso de automatización

Confiar solo en herramientas automáticas sin verificación manual humana.

Del laboratorio al mundo real

Casos prácticos

- *Web: inyección SQL en formulario de login que permitió acceso completo a la base de datos*
- *Mobile: almacenamiento inseguro de tokens que facilitó el robo de identidad*

Tendencias futuras

- *IA aplicada a la detección avanzada de patrones de vulnerabilidad*
- *Pentesting colaborativo mediante programas de bug bounty*
- *Análisis automatizado de código con ML*

SEGURIDAD INFORMATICA CARLA MORENO CIBERSEGURIDAD
CM
SEGURIDAD DE LA INFORMACION

La seguridad es un proceso continuo

El pentesting no es un evento puntual, sino parte de un ciclo de mejora constante. Implementa estas prácticas regularmente para mantener tus aplicaciones seguras.

¿Te ha resultado útil esta guía? Compártela con otros profesionales de seguridad y sígueme en @SecuMomDiaries para más contenido técnico sobre ciberseguridad.